

- HTTP Headers
- HSTS
- X-Frame-Options
- Referrer Policy
- X-Content-Type-Options
- X-Powered-By
- X-XSS-Protection
- CSP (Content-Security-Policy)

- HTTP Headers
 - 1. Request Header
 - 2. Response Header

HSTS (HTTP Strict Transpose Security)

- Strict-Transport-Security
 - It forces browser to use HTTPS protocol
 - [↗ developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Strict-Transport-Security](https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Strict-Transport-Security)

- X-Frame-Options
 - [↗ developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options](https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options)

- Referrer Policy
 - It controls how much reference information should be included with requests
 - [↗ developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Referrer-Policy](https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Referrer-Policy)

X-Content-Type-Options

- X-Content-Type-Options is a response header that tells the browser not to guess the type of a file and to trust the Content-Type sent by the server.
 - Server
 - Content-Type: text/plain
 - Response Body:
 - <script>alert("HI")</script>
 - MIME Sniffing.
 - nosniff - it tells the browser, don't open it based on your guess.
 - [↗ developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Content-Type-Options](https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Content-Type-Options)

- X-Powered-By
 - [↗ developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Powered-By](https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Powered-By)

- X-XSS-Protection
 - X-XSS-Protection is a legacy HTTP response header that instructed older browsers to enable their built-in XSS filter to detect and block reflected Cross-Site Scripting (XSS) attacks.
 - Modern browsers have deprecated or removed support for this header.
 - [↗ developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-XSS-Protection](https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-XSS-Protection)

CSP (Content-Security-Policy)

- CSP is an HTTP response header that tells the browser which JavaScript, CSS, images, fonts, and other resources are trusted.
 - If an attacker injects a malicious script from an untrusted source, the browser blocks it from loading or executing.
 - [↗ developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Content-Security-Policy](https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Content-Security-Policy)

